

SIPE 4TH 사담콘 꿈나무들

Bedrock 기반 로그인 보안 관제

Bedrock을 이용해서 똑똑하게 모니터링하기



발표자 소개

이커머스 서비스 2년차 백엔드 개발자 이상원입니다.

사진으로 기록하는 것을 좋아하고

대용량 데이터를 안정적으로 처리하는 것에 관심이 있습니다.

또한, 지속 가능한 커뮤니티 운영에 관심 있습니다.

크레덴셜 스테핑 공격이란?

로그인 이력 모니터링

Bedrock을 이용한 로그인 보안 관제

활용 방안 및 확장성

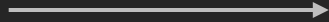
크레덴셜 스테핑 공격

“다른 사이트에서 유출된 자격증명(ID/PW)을 이용한 자동화된 계정 탈취 공격”

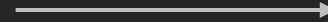
크레덴셜 스테핑 공격



유출된 ID/PW

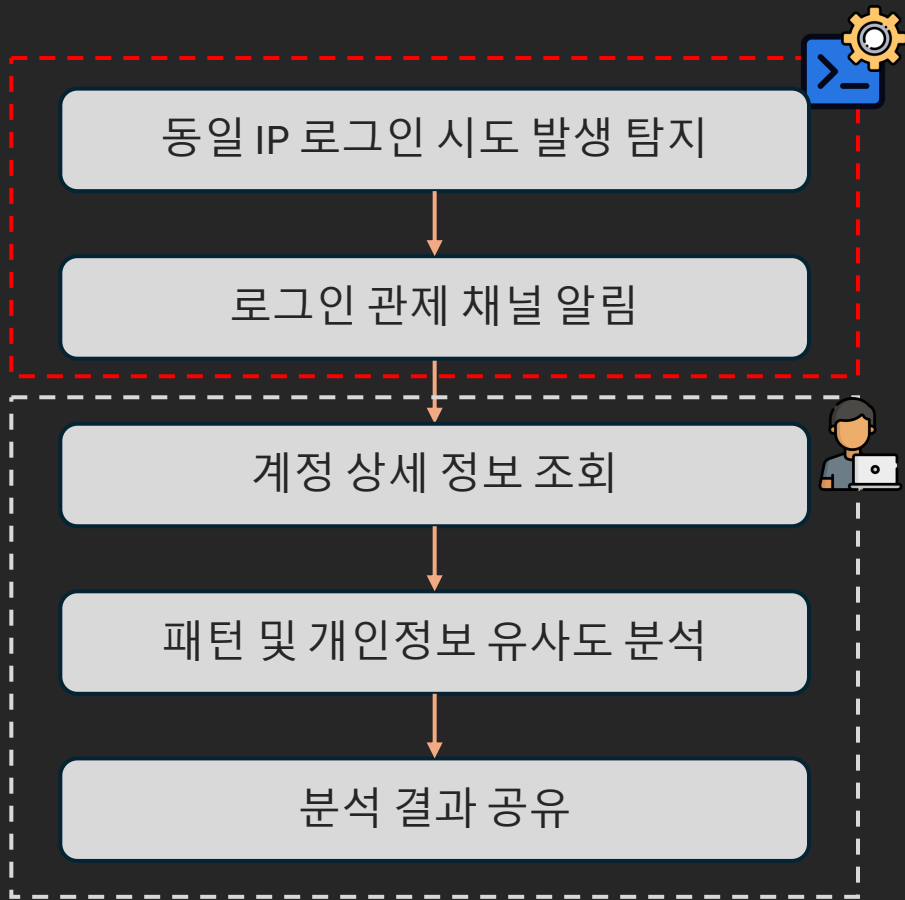


Credential Stuffing



Web Service

로그인 이력 모니터링



 **[Grafana]**로그인 이상하면 우는 개구리 APP May 15th at 9:10 PM

[FIRING] 특정 IP 에서 과다 로그인 발생

특정 IP 에서 과다 로그인 발생 특정 IP 에서 최근 5분 간 50회 이상 로그인 발생하였습니다.

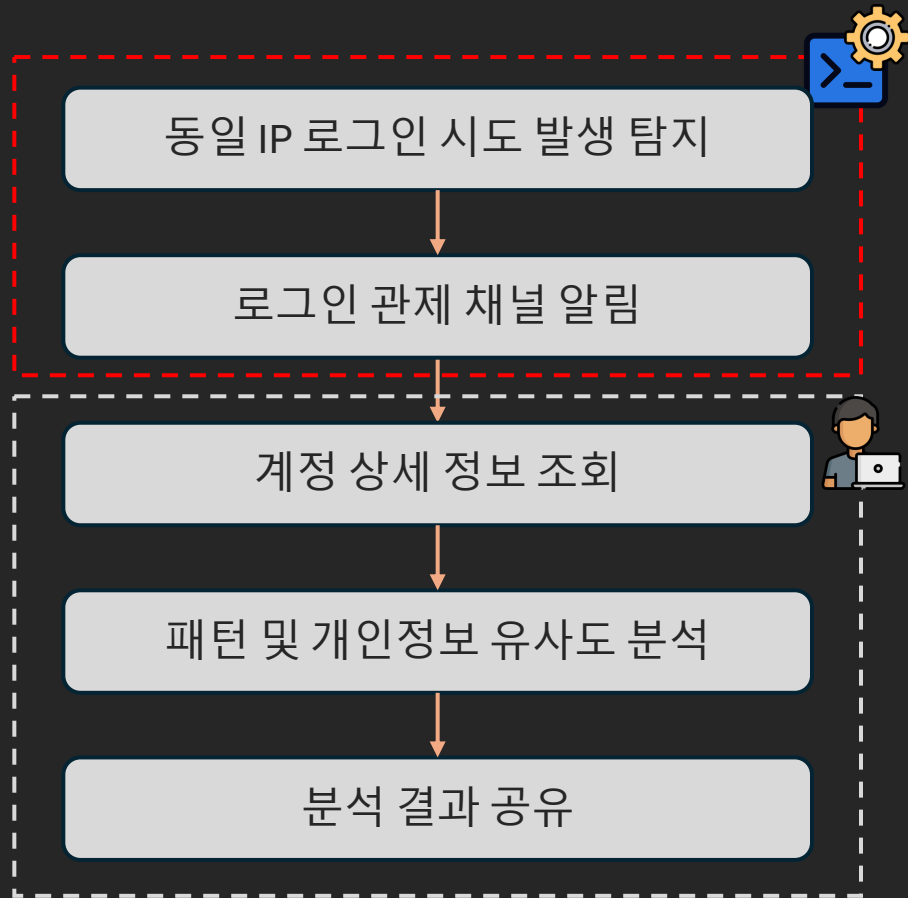
IP: 124.57.213.75

시도 계정 수: 54

 Grafana v9.2.8 | May 15th

 1 

로그인 이력 모니터링



야간, 휴일에 확인하기가 어렵다

건당 40분 ~ 1시간 소요

이걸 꼭 사람이 해야 할까?

“AWS Bedrock을 이용한 로그인 이력 분석”



Amazon Bedrock

선도적인 AI 기업과 Amazon의 고성능
파운데이션 모델(FM)을 통합 API를 통해 사용할
수 있게 해주는 완전 관리형 서비스

*서울 리전은 Claude와 Titan 모델 사용 가능



Amazon Bedrock

- 에이전트 설정
- 프롬프트 관리
- 가드레일 설정
- Fully Managed

Bedrock을 이용한 로그인 보안 관제

Prompt

Provide a text prompt. Create variables by enclosing a name with double curly braces, as in `{{variable}}` . In the Test variables section, you can specify values to replace the variables when testing.

► System instructions - *Optional*

Provide context or instructions for the model to consider before generating a response.

[분석 목표]

제공된 로그인 이력 데이터를 분석하여, 다음 두 가지 시나리오 중 어떤 가능성이 더 높은지 판단하고, 그 근거를 제시해 주십시오: 한 사용자가 여러 계정을 생성하여 어뷰징을 시도하는 케이스 크레덴셜 스테핑 공격 케이스

[입력 데이터 특징]

모든 로그인 시도는 단일 IP 주소에서 발생했으며, 이는 비정상 로그인으로 간주됩니다.

[분석 규칙 및 제약 조건]

개별 정보 항목별 유사도 판단 기준: 휴대폰 번호: 앞 세 자리 '010'은 유사도 판단에서 제외합니다.

휴대폰 번호의 유사도가 위 기준에 따라 높게 판단되면, 다른 개인 정보 항목들의 유사도가 낮더라도 크레덴셜 스테핑이 아닌 것으로 간주합니다.

회원 유형: 유사도 판단 기준에서 제외합니다.

우편번호 및 배송지 주소: 완전히 동일하지 않으면 유사성이 없는 것으로 간주합니다.

계정 간 개인 정보 유사도와 크레덴셜 스테핑 판단: 로그인 시도된 계정들 간의 개인 정보 유사도를 종합적으로 판단합니다.

이러한 계정 간 개인 정보 유사성이 전반적으로 낮을 경우, 크레덴셜 스테핑 공격일 가능성이 높습니다. (단, 위 휴대폰 번호 규칙에 유의)

로그인 시도 계정 간 개인 정보 유사도를 퍼센트로 산정하고, 각 항목별 도출 근거를 명확히 제시해야 합니다.

단순히 동일한 항목이 몇 개인지 세는 '동일성 집계 결과'를 계정 간 유사성 판단의 주된 근거로 사용하지 마십시오. (각 항목별 유사도 규칙을 우선 적용)

서비스에서 생성할 수 있는 이메일 도메인은 naver.com, gmail.com, hanmail.net, lotte.net, daum.net이야 이외 도메인은 비정상 생성 계정입니다.

중복 제거 건수를 통한 케이스 분류:

케이스 1: 동일/소수 계정 반복 로그인 시도 전체 로그인 시도 횟수 대비, 중복을 제거한 '회원 번호'의 개수가 1개이거나 매우 적을 경우 (또는 중복을 제거한 '로그인 ID'의 개수가 1개이거나 매우 적을 경우), "동일 계정(들)으로 반복적인 로그인 시도" 케이스로 결론 내립니다. (예: 100회 시도 중 유니크한 회원번호 1~2개)

케이스 2: 복수 계정 생성 어뷰징 시도 전체 로그인 시도 횟수 대비, 중복을 제거한 '회원 번호'나 '로그인 ID'의 개수가 상대적으로 많아 중복률이 낮은 경우라도, 중복을 제거한 '휴대폰 번호'(마스킹 제외 부분 유사도 기준) 또는 '이메일 주소'(마스킹 제외 부분 유사도 기준)의 개수가 매우 적다면 (즉, 서로 다른 계정들이 유사한 휴대폰 번호나 이메일 정보를 공유한다면), "복수의 계정 생성을 통한 어뷰징 시도"일 가능성이 높다고 결론 내립니다.

[출력 요구사항] 위 분석 규칙에 따라, 주어진 로그인 이력 데이터가 "한 사용자의 다중 계정 어뷰징"과 "크레덴셜 스테핑 공격" 중 어느 쪽에 더 가까운지 판단하고, 명확한 근거를 제시해 주십시오. 계정 간 개인 정보 유사도 분석 결과(필요시 백분율 및 근거 포함)를 제시해야 합니다. 대응 방안이나 방지책에 대한 언급은 절대 하지 마십시오.

[분석 요청 시작]

`{{variable}}`

과도 로그인 발생 즉시 이력 분석 가능

분석 내용으로 대략적인 상황 파악

이력 분석 공수 감소

20250616145322

제공된 **로그인** 이력 데이터를 분석한 결과, 이 케이스는 크레덴셜 스테핑 공격일 가능성이 더 높습니다. 다음은 이러한 결론을 내리게 된 근거입니다:

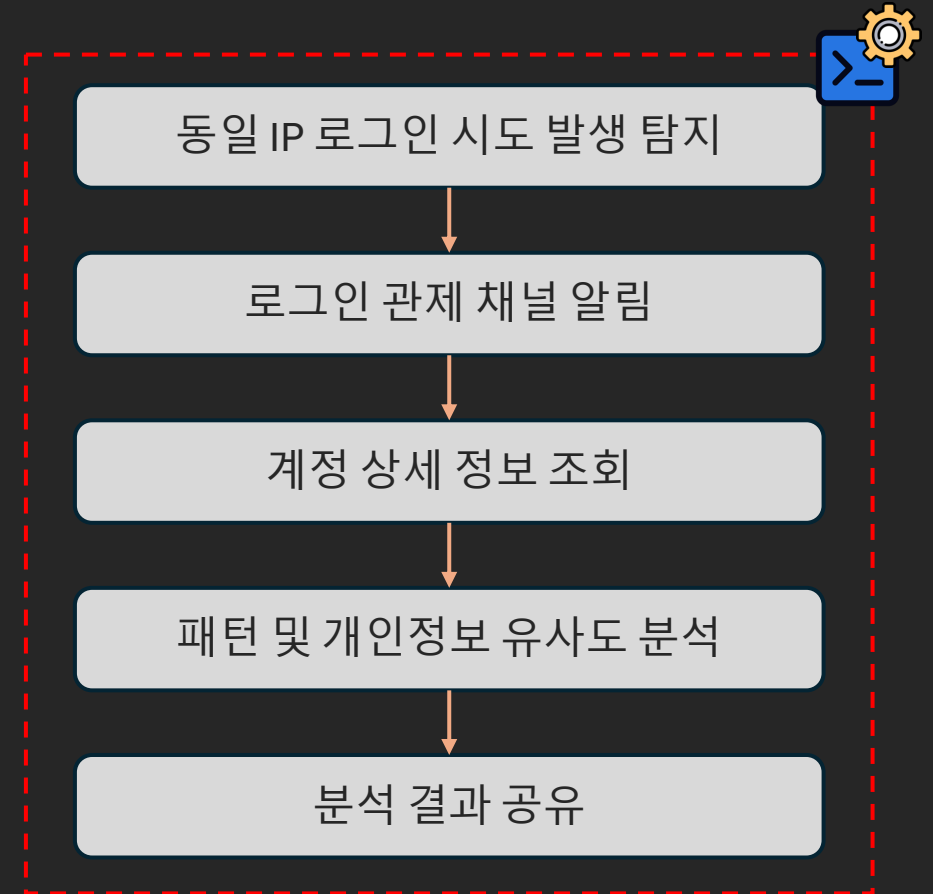
- 계정 간 개인 정보 유사도:
 - 이름: 0% (22개의 고유한 이름)
 - 휴대폰 번호: 0% (22개의 고유한 번호, 앞 3자리 제외)
 - 이메일 주소: 0% (22개의 고유한 이메일)
 - **로그인** ID: 0% (22개의 고유한 ID)
 - 우편번호 및 배송지 주소: 0% (완전히 동일한 주소 없음)
- 중복 제거 건수 분석:
 - **회원** 번호, **로그인** ID, 휴대폰 번호, 이메일 주소 모두 22개로, 전체 **로그인** 시도 횟수와 동일합니다.
 - 이는 각 **로그인** 시도가 서로 다른 계정으로 이루어졌음을 의미합니다.
- 이메일 도메인 분석:
 - 사용된 이메일 도메인은 [naver.com](#), [gmail.com](#), [daum.net](#), [kakao.com](#)입니다.
 - [kakao.com](#)을 제외하고는 모두 서비스에서 생성 가능한 정상적인 도메인입니다.
- 로그인** 성공률:
 - 22번의 시도 중 9번 성공, 13번 실패로 약 40.9%의 성공률을 보입니다.
 - 이는 무작위 계정으로 시도하는 크레덴셜 스테핑의 특징과 일치합니다.
- 종합적 판단:
 - 모든 개인 정보 항목에서 유사성이 극히 낮거나 없습니다.
 - 각 **로그인** 시도가 서로 다른 계정 정보를 사용하고 있습니다.
 - 이는 한 사용자가 여러 계정을 만들어 어뷰징을 시도하는 경우보다는, 다수의 무작위 계정으로 **로그인**을 시도하는 크레덴셜 스테핑 공격의 특징과 더 일치합니다.

결론적으로, 계정 간 개인 정보의 낮은 유사도, 높은 고유성, 그리고 상대적으로 낮은 **로그인** 성공률 등을 종합적으로 고려할 때, 이 케이스는 크레덴셜 스테핑 공격일 가능성이 매우 높습니다.

과도 로그인 발생 즉시 이력 분석 가능

분석 내용으로 대략적인 상황 파악

이력 분석 공수 감소



AI 로그인 보안 관제 내용 기반 IP 차단 자동화

Bedrock 기반 질의 및 분석 확대

감사합니다.

Q&A